

2026-05-05



Finansinspektionen
Box 7821
103 97 Stockholm
Tel +46 8 408 980 00
finansinspektionen@fi.se
www.fi.se

Justitiekanslern
Box 2308
103 17 Stockholm

FI dnr 26-7652

Endast via e-post: registrator@justitiekanslern.se

Yttrande i ärende om skadeståndsanspråk mot staten, dnr 2026/1950

Med anledning av Justitiekanslerns remiss får Finansinspektionen (FI) yttra sig i rubricerat ärende.

Sammanfattning

FI anser att myndigheten varken har brustit i sin tillsyn enligt Dora-regelverket eller överträtt någon rättsregel. Enligt myndighetens bedömning har det inte framkommit någon omständighet som medför skadeståndsskyldighet för staten, varken enligt Francovich-principen eller enligt skadeståndslagen (1972:207). Beträffande den ekonomiska skada som Gillsoft AB anser sig ha lidit och begär ersättning för bedömer FI att kostnaden grundas i ett rent affärsmässigt beslut av bolaget som inte har något samband med FI:s verksamhet eller beslut.

Omständigheter som anspråket hänför sig till

FI vill inledningsvis informera att myndighetens tillsyn på IKT-området rör de finansiella entiteter som omfattas av Dora-regelverket och dessas efterlevnad av Dora-förordningen¹. Gillsoft AB är inte en finansiell entitet i Dora-förordningens mening, men däremot en tredjepartsleverantör av IKT-tjänster (se avsnittet *Särskilt om Dora-förordningen* nedan). FI bedriver inte tillsyn av tredjepartsleverantörerna. Gillsoft AB är alltså inte en sådan finansiell entitet vars verksamhet direkt omfattas av det tillsynsarbete som följer av FI:s tillsynsstrategi och årliga tillsynsprioriteringar. FI har inte fattat något beslut där Gillsoft AB förekommer som part i ärendet.

Gillsoft AB hänvisar i sitt skadeståndsanspråk till två anmälningar som bolaget ska ha gjort till FI. Den första anmälan som bolaget hänvisar till, dnr 25-2410,

¹ Europaparlamentets och rådets förordning (EU) 2022/2554 av den 14 december 2022 om digital operativ motståndskraft för finanssektorn och om ändring av förordningarna (EG) nr 1060/2009, (EU) nr 648/2012, (EU) nr 600/2014, (EU) nr 909/2014 och (EU) 2016/1011.

är dock gjord av en anonym avsändare. I mejlet påtalar anmälaren bl.a. att denne anser att det är ett absolut krav att Getswish AB eller medlemsbankerna kontrollerar att alla kunder som har tjänsten Swish utbetalning har en HSM (hårdvarusäkerhetsmodul). Vidare konstaterar anmälaren att medlemsbankerna redan genom avtal kräver att beställaren av tjänsten Swish utbetalning använder en HSM. FI har inom ramen för myndighetens serviceskyldighet skickat ett brevsvår till anmälaren och i korthet beskrivit sitt tillsynsarbete och tackat för informationen.

Gillsoft AB har även skickat en fråga till FI om FI:s tillsynsmetod avseende verifiering av kryptografisk nyckelhantering under DORA-förordningen (EU) 2022/2554, dnr 26-6336. FI har inom ramen för myndighetens serviceskyldighet skickat ett brevsvår till bolaget och informerat att myndigheten bedriver sin tillsyn genom flera olika metoder.

Rättsliga förutsättningar

Särskilt om Dora-förordningen

Dora-regelverket, det vill säga Dora-förordningen med tillhörande genomförandeförordningar och delegerade förordningar, syftar till att säkerställa den digitala operativa motståndskraften i den finansiella sektorn och gäller för i stort sett alla finansiella företag. Regelverket är relativt nytt, och började tillämpas i januari 2025. Genomförandeförordningar och delegerade förordningar har därefter tillkommit löpande under hela 2025.

Vilka som utgör finansiella entiteter enligt Dora-förordningen framgår av artikel 2, där olika entitetstyper listas, tillsammans med artikel 3, där entitetstyperna identifieras genom hänvisning till andra europeiska regelverk inom finanssektorn. Genom bl.a. artikel 46 i Dora-förordningen ges FI rättsligt stöd för sin tillsyn av de uppräknade finansiella entiteterna.

Dora-regelverket innehåller skyldigheter rörande bland annat riskhantering inom informations- och kommunikationsteknik (IKT), incidentrapportering av allvarliga IKT-incidenter, testning av digital operativ motståndskraft och hantering av tredjepartsrelaterade IKT-risker. Vidare ställer Dora-regelverket också krav på de finansiella företagens kontraktsmässiga arrangemang med deras tredjepartsleverantörer av IKT-tjänster. I Dora-förordningen regleras också bland annat olika typer av informationsutbyten mellan såväl offentliga som privata aktörer, och den tillsyn av *kritiska* IKT-tredjepartsleverantörer (se artikel 31 i Dora-förordningen) som leds av de europeiska tillsynsmyndigheterna (Europeiska Bankmyndigheten, Europeiska försäkrings- och tjänstepensionsmyndigheten samt Europeiska värdepappers- och marknadsmyndigheten).

I artikel 3 i Dora-förordningen finns definitioner av bland annat begreppen *tredjepartsleverantör av IKT-tjänster* och *IKT-tjänster*.²

Enligt artikel 6 i Dora-förordningen ska de finansiella entiteterna ha en IKT-riskhanteringsram. Kraven på denna IKT-riskhanteringsram är omfattande och ska enligt artikel 6.2 ”(...) *omfatta åtminstone de strategier, riktlinjer, förfaranden, IKT-protokoll och IKT-verktyg som är nödvändiga för att på ett vederbörligt och adekvat sätt skydda alla informations- och IKT-tillgångar* (...)”. Dora-förordningens efterföljande artiklar innehåller i flera fall tillkommande information om kraven på de finansiella företagens IKT-riskhanteringsram.

Dora-förordningen ställer i artikel 9 krav på de finansiella entiteternas arbete med att skydda IKT-system och upprätthålla höga standarder för informations-säkerheten. För att uppnå dessa mål ska de finansiella entiteterna, enligt artikel 9.3, använda IKT-lösningar och IKT-processer som är lämpliga i enlighet med artikel 4 i Dora-förordningen, och det krävs att dessa lösningar och processer ska (i) säkerställa skydd vid dataöverföring, (ii) minimera risk för förvanskning eller förlust av uppgifter, obehörig åtkomst eller tekniska brister som kan hindra affärsverksamheten, (iii) förhindra bristen på tillgänglighet, försvagandet av äkthet och integritet, överträdelserna av konfidentialitet, och förlusten av data och (iv) säkerställa att uppgifterna skyddas mot risker som uppstår från datahantering, inbegripet bristfällig förvaltning, processrelaterade risker och den mänskliga faktorn.

Artikel 9.4 i Dora-förordningen gör en ytterligare nedbrytning av vad de finansiella entiteternas IKT-riskhanteringsram, som avses i artikel 6 i Dora-förordningen, ska bestå av när det gäller skydd av IKT-systemen. I denna del anges bland annat att IKT-riskhanteringsramen ska ”(...) *d) genomföra strategier och protokoll för starka äkthetsmekanismer, baserade på relevanta standarder och särskilda kontrollsystem, samt skyddsåtgärder för kryptografiska nycklar där data krypteras baserat på resultat från godkända processer för klassificering och IKT-riskbedömning* (...)”.

Artikel 28 i Dora-förordningen ställer krav på att de finansiella entiteterna hanterar sina IKT-tredjepartsrisker som en integrerad del av sin IKT-riskhanteringsram. Här anges bland annat, i punkt 5, att kontraktsmässiga arrangemang endast får ingås med tredjepartsleverantörer av IKT-tjänster som uppfyller lämpliga standarder för informationssäkerhet. Artikel 28 innehåller i övrigt krav på den finansiella entiteten gällande bland annat *due diligence* inför kontraktsskrivning, och säkerställande av möjlighet till avslut av kontraktsmässiga arrangemang under omständigheter som anges särskilt i artikeln.

² Artikel 3.19 i Dora-förordningen anger att en *tredjepartsleverantör av IKT-tjänster* är ”ett företag som tillhandahåller IKT-tjänster”. Artikel 3.21 i Dora-förordningen anger att *IKT-tjänster* är ”digitala tjänster och datatjänster som fortlöpande tillhandahålls genom IKT-system till en eller flera interna eller externa användare, inbegripet maskinvara som tjänst och maskinvarutjänster som inbegriper tillhandahållande av teknisk support genom uppdateringar av programvara eller fast programvara från maskinvaruleverantören, ej inbegripet traditionella analoga telefontjänster”.

Av artikel 30 i Dora-förordningen framgår vilka delar som de kontraktsmässiga arrangemangen (det vill säga avtalen) för användningen av IKT-tjänster åtminstone ska innehålla. Här anges i artikel 30.2 c att de kontraktsmässiga arrangemangen bland annat ska innehålla *”bestämmelser om tillgänglighet, äkthet, integritet och konfidentialitet vad gäller skydd av data, inbegripet personuppgifter”*.

Artikel 9 i Dora-förordningen kompletteras av den Europeiska kommissionens delegerade förordning (EU) 2024/1774 om komplettering av Europaparlamentets och rådets förordning (EU) 2022/2554 vad gäller tekniska standarder för tillsyn som specificerar verktyg, metoder, processer och strategier för IKT-riskhantering och den förenklade IKT-riskhanteringsramen (RTS 2024/1774). Enligt artikel 2.1 c i RTS 2024/1774 ska de finansiella entiteterna inrätta IKT-relaterade säkerhetsstrategier, förfaranden, protokoll och verktyg som bland annat *”bevarar uppgifternas tillgänglighet, äkthet, integritet och konfidentialitet, inbegripet genom användning av krypteringsmetoder”*.

I artikel 6 i RTS 2024/1774 finns mer detaljerade regler om just kryptering och kryptografisk säkerhet, närmare bestämt krav på den finansiella entiteten att ha en dokumenterad policy för just detta. Kortfattat beskrivet stadgar artikeln att policyn ska innehålla regler om kryptering av uppgifter i vila och under överföring samt (vid behov) i bruk. Policyn ska inkludera de kriterier som den finansiella entiteten använder vid val av krypteringsmetod, och bestämmelser om uppdatering och ändringar (vid behov) av vald krypteringsteknik. I artikel 7 i RTS 2024/1774 anges att de finansiella entiteterna ska ha en heltäckande policy för sin hantering av kryptografiska nycklar för hela deras livscykel, från generering till förstörelse. Av artikeln framgår vidare att de finansiella entiteterna ska genomföra kontroller för att skydda de kryptografiska nycklarna, utveckla och genomföra metoder för att ersätta förlorade, komprometterade eller skadade nycklar. Ett register ska upprättas och upprätthållas över alla certifikat och certifikatslagringsenheter för åtminstone de IKT-tillgångar som stöder entitetens kritiska och viktiga funktioner. Entiteten är också skyldig att säkerställa att certifikat snabbt förnyas innan de löper ut.

Finansinspektionens tillsynsstrategi och prioriteringar inom IKT-risktillsynen

FI ansvarar för tillsynen, regelgivningen, tillståndsprövningen och registreringen som rör finansiella marknader och finansiella företag. I uppgiften ingår att arbeta för ett stabilt finansiellt system, som präglas av ett högt förtroende och sund konkurrens, och som har förmåga att säkerställa viktiga samhällsfunktioner. De finansiella marknaderna ska vara väl fungerande. Myndigheten arbetar också för att de finansiella företagen ska tillgodose hushållens och företagens behov av finansiella tjänster, ta sitt ansvar för ett starkt konsumentskydd, samt medverka till en hållbar utveckling.

Sättet som FI bedriver sitt tillsynsarbete på finns beskrivet i FI:s tillsynsstrategi.³ Tillsynen bedrivs för att säkerställa att finansmarknadens aktörer agerar i enlighet med gällande regelverk och på så sätt bidrar till en stabil och välfungerande finansmarknad. Brister i efterlevnaden kan leda till betydande konsekvenser för såväl samhällsekonomin som för enskilda företag och konsumenter. FI:s arbete med IKT-risktillsyn utgår från denna övergripande tillsynsstrategi.

Genom Dora-förordningen har FI fått ett utökat och mer omfattande uppdrag inom tillsyn av IKT-risker. Även omfattningen av vilka aktörer som omfattas är mycket bred. Dora-förordningen och de omfattande genomförandeförordningarna träffar i princip samtliga finansiella aktörer som har tillstånd från FI och som står under FI:s tillsyn, vilket är drygt 2 000 företag.

Liksom i övrig tillsyn tillämpar FI inom IKT-området en riskbaserad tillsynsmetod. Den riskbaserade tillsynsmetoden bygger på globala standarder för tillsyn på finansmarknadsområdet⁴. Det innebär att resurser prioriteras till de områden där riskerna är höga och där potentiella konsekvenser vid bristande efterlevnad kan bli stora. Tillsynen baseras alltid på en grundlig analys, och aktiviteterna anpassas för att uppnå bästa möjliga resultat.

Alla aktörer under FI:s tillsyn är föremål för löpande tillsyn. Genom planerade analyser och granskningar, såväl kvantitativa som kvalitativa, ser FI till att finansiella företag och marknadstransaktioner uppfyller de regler och krav som ställs på dem. Den löpande tillsynen är också till viss del händelsestyrd och ger tillsammans med resultaten av myndighetens planerade analyser och granskningar underlag för myndighetens riskbaserade prioriteringar. En central del består av skriftlig och muntlig tillsynsdialog, som gör det möjligt för FI att följa utvecklingen av till exempel IKT-risker hos företagen och på marknaden i stort.

Utöver den löpande tillsynen kan FI initiera fördjupade analyser och undersökningar. Fördjupade analyser inom IKT-risktillsynen syftar till att fördjupa FI:s förståelse för specifika IKT-relaterade frågeställningar och risker. Enkäter, som nämns i skadeståndsanspråket, är ett exempel på en typ av fördjupad analys genom vilken FI brett kartlägger hur företagen förhåller sig till skyldigheterna och kraven i Dora-förordningen. Eftersom Dora-förordningen började tillämpas av företagen först den 17 januari 2025 utgör enkäternas resultat ett viktigt verktyg för de prioriteringar som sker i den riskbaserade tillsynen.

I FI:s prioriteringar i tillsynen för 2026 pekas IKT-risker ut som en av myndighetens tillsynsprioriteringar: *”Vi ska under 2026 fortsatt arbeta med tillsyn av informations- och kommunikationsteknologirisker (IKT-risker) och säkerhetsskydd. Vi ska särskilt analysera inrapporterade data kopplad till*

³ Tillsynsstrategi (1 november 2022), FI dnr 22-24464.

⁴ Se t.ex. FATF (Financial Action Task Force) guidance on risk-based supervision och Basel-ramverket, Core principles for effective banking supervision.

regelverket Digital Operational Resilience Act (Dora) för att identifiera risker och för att säkerställa en god efterlevnad av regelverket.”⁵

Finansinspektionens bedömning

Fråga om rätt till skadestånd enligt Francovich-principen

Gillsoft AB anser att FI har brustit i sin tillsyn och att bolaget därför har rätt till skadestånd för dess kostnader för att ha investerat i en viss hårdvara, licenser och publiceringskostnader. Till stöd för sin uppfattning har Gillsoft AB hänvisat till ett flertal bestämmelser i Dora-regelverket, som enligt bolaget i praktiken innebär krav som förutsätter att de finansiella entiteterna använder en automatiserad kryptografisk verifiering av nyckelhantering.

FI anser att myndigheten varken har brustit i sin tillsyn eller överträtt någon rättsregel. Gillsoft AB är en tredjepartsleverantör enligt Dora-förordningen (se artikel 3.19 i Dora-förordningen) och inte en finansiell entitet (jfr artikel 2.2 i Dora-förordningen). FI konstaterar först att Dora-regelverkets bestämmelser om IKT-riskhantering, däribland kraven som behandlar informationssäkerhet och skydd genom kryptering, innebär skyldigheter för finansiella företag (entiteter) och inte rättigheter för tredjepartsleverantörer av IKT-tjänster som Gillsoft AB. Som tredjepartsleverantör av IKT-tjänster står inte Gillsoft AB under FI:s tillsyn (jfr artikel 46 i Dora-förordningen) och myndigheten har inte heller fattat något beslut där bolaget är part. Värt att notera är att även om FI i sin tillsyn specifikt kontrollerar om de finansiella entiteterna verifierar kryptografisk nyckelhantering innebär det inte att Gillsoft AB skulle få en rättighet. Det första kravet enligt Francovich-principen, dvs. att den överträdde rättsregeln ska vara avsedd att skapa rättigheter för enskilda, är därmed inte uppfyllt.

Beträffande tillsynsarbetet konstaterar FI vidare att Dora-regelverket, som redogjorts för ovan, är ett omfattande regelverk som ska tillämpas i förhållande till i princip alla FI:s tillsynsobjekt. FI tillämpar en riskbaserad tillsynsmetod som innebär att IKT-risktillsynen utgår från de risker som myndigheten bedömer som de största. Att FI tillämpar en riskbaserad tillsynsmetod i enlighet med globala standarder innebär inte att det skett en överträdelse av unionsrätten eller en enskilds rättigheter.

Mot denna bakgrund anser FI att inte heller det andra kravet enligt Francovich-principen är uppfyllt, dvs. att det ska ha skett en överträdelse av unionsrätten som ska vara tillräckligt klar.

Eftersom det enligt FI:s bedömning inte finns någon överträdelse från myndighetens sida anser myndigheten att det inte heller finns något orsakssamband med den skada Gillsoft AB anser sig ha lidit. FI:s bedömning är därför att inte heller det sista kravet enligt Francovich-principen är uppfyllt,

⁵ FI:s prioriteringar i tillsynen 2026 (2026-02-05), FI dnr 26-1304.

dvs. att det måste finnas ett direkt orsakssamband mellan överträdelsen och den skada som den enskilde har lidit. FI anser därför att bolagets yrkande om skadestånd på denna grund bör avslås.

Fråga om rätt till skadestånd enligt skadeståndslagen

Som tidigare nämnts har FI inte fattat något beslut där Gillsoft AB är part och bolaget står inte under myndighetens tillsyn. FI har endast inom ramen för sin serviceskyldighet svarat på ett e-postmeddelande från bolaget (dnr 26-6336). Bolaget har således inte varit föremål för någon myndighetsutövning från FI:s sida. Bolaget har heller inte visat att det förekommit något fel eller försummelse från myndighetens sida i bolagets kontakter med FI eller att inspektionen lämnat bolaget några felaktiga råd eller upplysningar. Det har inte heller lagts fram några omständigheter som skulle kunna innebära att det förekommit någon överträdelse av Europakonventionen i förhållande till bolaget.

När det gäller den skada om 352 000 kr som Gillsoft AB anser sig ha lidit uppger bolaget att skadan motsvarar kostnader för inköp av en viss hårdvara, licenser och publiceringskostnader i syfte att erbjuda en tjänst som bolaget bedömer är till nytta för finansiella entiteter i dessas efterlevnad av Dora-regelverket. FI anser att en sådan investering grundas i ett rent affärsmässigt beslut av bolaget som inte har något samband med FI:s verksamhet eller beslut. Den är inte heller ett resultat av försumligt eller på annat sätt skadeståndsgrundande handlande av FI.

FI anser sammantaget att förutsättningarna för skadestånd enligt skadeståndslagen inte är uppfyllda och att bolagets yrkande även på denna grund ska avslås.

FINANSINSPEKTIONEN

Erik Blommé
Chefsjurist

Ashtar Yakob
Senior jurist

Dokumentet är elektroniskt undertecknat.